COMPTIA SECURITY+ SY0-701 | DOMÍNIO 1 · CONCEITOS GERAIS DE SEGURANÇA (12%)

Security+ 1.2 · AAA (Authentication, Authorization, Accounting)

Mestre CyberSec · **Aula 1.2 — AAA (Authentication, Authorization, Accounting)** (9:03) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** AAA: Authentication (prova quem é), Authorization (o que pode fazer), Accounting (registra o que fez). 802.1X usa RADIUS pra AAA de rede — quem conecta o cabo precisa se autenticar antes de ter acesso.

💡 Highlights que a prova CompTIA cobra

- 'Prove quem és, define o que podes, registra o que fez'
- 802.1X: acesso físico à rede precisa de login — sem isso, qualquer dispositivo entra
- RADIUS = o backend central de AAA

🎯 Dicas de Prova & Cenários Típicos da Banca

- A prova menciona: 'network access control requires users to authenticate' = 802.1X + RADIUS
- Accounting = LOG de acesso (quem entrou quando) — não é accounting financeiro

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 1.2 — AAA (Authentication, Authorization, Accounting))

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• AAA (Autenticação, Autorização, Accounting/Auditoria)
Estrutura de segurança que combina Autenticação (provar quem é), Autorização (definir o que pode fazer) e Accounting (registrar o que fez). É o modelo padrão para controlar e auditar acesso a redes e sistemas na prova SY0-701.

⚠️ ***Armadilha CompTIA:*** *'Prove quem és, define o que podes, registra o que fez.' Se a pergunta disser 'track/record what the user did', a resposta é Accounting — cuidado com a pegadinha de achar que se trata de contabilidade financeira.*

• Autenticação (AuthN)
Processo de verificar a identidade do usuário usando credenciais como senhas, smart cards ou biometria antes de conceder qualquer acesso.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'verify identity' / 'prove who you are' = Authentication. Distinção chave: autenticação responde 'quem é você'; autorização responde 'o que você pode fazer' — a prova adora trocar as duas.*

• Autorização (AuthZ)
Define os direitos e permissões concedidos a um usuário já autenticado — quais recursos ele pode acessar e quais ações pode executar.

⚠️ ***Armadilha CompTIA:*** *Ordem importa: primeiro Authentication, depois Authorization. Gatilho: 'what are you allowed to access/do' = Authorization; 'who are you' = Authentication.*

• Accounting (Auditoria/Registro de atividades) (Acct)
Função do AAA que registra em log a atividade e os eventos de acesso do usuário — quem conectou, quando e quais recursos foram usados — criando uma trilha de auditoria (audit trail).

⚠️ ***Armadilha CompTIA:*** *Na prova, Accounting = LOG de acesso (quem entrou e quando). Gatilho: 'track user access' ou 'maintain logs of usage' → Accounting. NÃO é accounting financeiro — pegadinha clássica do termo.*

• IEEE 802.1X (Controle de acesso por porta)
Padrão IEEE de controle de acesso à rede baseado em porta que bloqueia todo o tráfego na porta do switch ou conexão wireless até o cliente se autenticar; o switch/ponto de acesso encaminha as credenciais ao servidor de

autenticação (RADIUS).

⚠️ ***Armadilha CompTIA:*** *Trigger da prova: 'network access control requires users to authenticate before connecting' ou 'port-based authentication' = 802.1X. Sem 802.1X, qualquer dispositivo que conecta o cabo entra na rede. Papéis: Supplicant (cliente), Authenticator (switch/AP), Authentication Server (RADIUS).*

• RADIUS (Serviço Remoto de Autenticação de Usuário Discado)

Protocolo AAA centralizado que fornece autenticação, autorização e accounting para acesso à rede; backend mais comum usado junto com o 802.1X. Usa UDP 1812/1813 e criptografa apenas o campo da senha.

⚠️ ***Armadilha CompTIA:*** *Dupla clássica da prova: 802.1X (na porta do switch) + RADIUS (backend central de AAA). Distinção para não errar: RADIUS = UDP, cripta só a senha, foco em acesso à rede; TACACS+ = TCP 49, cripta tudo, foco em administração de dispositivos.*

• TACACS+ (Sistema Plus de Controle de Acesso)

Protocolo AAA desenvolvido pela Cisco que criptografa o pacote inteiro, separa cada função do AAA e é tipicamente usado para administrar dispositivos de rede; roda sobre TCP porta 49.

⚠️ ***Armadilha CompTIA:*** *Comparação obrigatória da prova: RADIUS (UDP 1812/1813, cripta só a senha, acesso à rede/802.1X) vs TACACS+ (TCP 49, cripta tudo, device administration). Trocar esses dois na questão = erro clássico.*

• NAC (Controle de Acesso à Rede)

Abordagem de segurança que determina se um dispositivo pode ingressar na rede, tipicamente exigindo autenticação (e às vezes checagens de integridade do dispositivo) antes de conceder acesso; o 802.1X é sua implementação de autenticação baseada em porta.

⚠️ ***Armadilha CompTIA:*** *Quando a prova escrever 'network access control requires users to authenticate', a resposta é 802.1X + RADIUS. Distinção: NAC é o conceito amplo (pode incluir posture checks); 802.1X é o mecanismo de autenticação por porta que a citação descreve.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Os Três Pilares: Autenticação, Autorização e Contabilidade/Auditoria

🏠 **Analogia Intuitiva:** A portaria de um condomínio empresarial corporativo de alta segurança. Primeiro, você entrega sua carteira de identidade oficial com foto ao guarda para provar quem você é (Autenticação). Em seguida, o guarda consulta o sistema e programa seu crachá para abrir exclusivamente a porta do departamento financeiro no 4º andar, mantendo todas as outras salas trancadas (Autorização). Por fim, o sistema da catraca registra o minuto exato da sua entrada, quanto tempo permaneceu no prédio e o horário da saída (Accounting).

🔍 **Causa Raiz / Por que foi criado:** Sem a divisão estrita de AAA, sistemas antigos concediam acesso total assim que o usuário acertava uma senha básica (misturando autenticação com permissão irrestrita) ou não registravam as ações dos colaboradores, tornando impossível descobrir os responsáveis por vazamentos de dados.

🛡️ **Visão do Auditor de GRC:** O auditor de segurança fiscaliza os três pilares separadamente: 1) MFA e integração com diretório corporativo (Autenticação); 2) Princípio do Menor Privilégio e Segregação de Funções - SoD (Autorização); 3) Centralização e retenção de logs de eventos e acessos no SIEM por pelo menos 1 ano (Accounting).

⚠️ **Como cai na Prova CompTIA:** Distinção vital para a prova: Autenticação = validar QUEM você é (senhas, biometria, tokens). Autorização = definir QUAIS recursos você pode acessar (permissões NTFS, regras de grupo). Accounting = registrar O QUE você fez e quanto tempo usou (logs de auditoria, tempos de conexão, uso de banda).

📌 Autenticação em Nível de Porta de Rede: Padrão IEEE 802.1X

🏠 **Analogia Intuitiva:** Uma tomada de parede inteligente em um escritório que não fornece nem uma faísca de eletricidade até que um crachá de funcionário cadastrado seja encostado no sensor da parede. Se um visitante conectar o cabo de rede do seu notebook na tomada da sala de reunião, a porta do switch permanece morta e isolada até que ele faça login com credenciais corporativas válidas.

🔍 **Causa Raiz / Por que foi criado:** Qualquer pessoa física que entrasse em um prédio comercial (entregadores, visitantes, terceirizados) poderia plugar um cabo em uma tomada de rede livre e ter acesso instantâneo a servidores confidenciais da rede interna sem passar por nenhum firewall.

🛡️ **Visão do Auditor de GRC:** O auditor de redes verifica se a política de Network Access Control (NAC) via 802.1X está ativada em todos os switches e access points Wi-Fi, garantindo que dispositivos não gerenciados ou sem certificado sejam redirecionados para uma VLAN de quarentena de convidados.

⚠️ **Como cai na Prova CompTIA:** Palavras-chave do cenário: 'Port-based network access control', 'Enterprise Wi-Fi requiring credentials prior to network access', 'Supplicant, Authenticator, Authentication Server'. Resposta da CompTIA: IEEE 802.1X (usando RADIUS no backend).

📌 Protocolos Centrais de AAA: RADIUS vs. TACACS+

🏠 **Analogia Intuitiva:** RADIUS é como o bilhete único do transporte público: você passa o cartão na catraca e ele combina a checagem do seu crédito com a liberação da catraca no mesmo segundo (Autenticação e Autorização combinadas) usando UDP veloz. Já o TACACS+ é como a sala de controle de lançamento de foguetes da NASA: cada comando individual digitado pelo técnico ('ligar turbina', 'alterar rota') é inspecionado isoladamente através de um canal totalmente criptografado (TCP) e autorizado comando por comando.

🔍 **Causa Raiz / Por que foi criado:** Administrar contas locais de administrador em centenas de switches, roteadores e servidores VPN gerava descontrole: senhas desatualizadas, contas esquecidas e incapacidade de revogar o acesso imediatamente quando um engenheiro de rede pedia demissão.

🛡️ **Visão do Auditor de GRC:** O auditor fiscaliza: 1) TACACS+ para gerenciamento de equipamentos de infraestrutura (roteadores e switches Cisco/Juniper), permitindo auditoria de cada comando CLI executado pelo administrador; 2) RADIUS para autenticação de rede de ponta (802.1X, Wi-Fi WPA3-Enterprise e VPNs de usuários).

⚠️ **Como cai na Prova CompTIA:** A tabela comparativa clássica da CompTIA: RADIUS = UDP (portas 1812/1813), combina Autenticação e Autorização, e cifra apenas o campo da senha. TACACS+ = TCP porta 49, SEPARA Autenticação, Autorização e Accounting, e cifra TODO o pacote de dados. Gerenciamento de roteadores/switches = TACACS+. Acesso de usuários finais Wi-Fi/802.1X/VPN = RADIUS.

📌 Accounting: A Trilha de Auditoria e Contabilização de Uso

🏠 **Analogia Intuitiva:** O tacógrafo lacrado de um caminhão de carga e a fatura detalhada do cartão de crédito. O tacógrafo não decide quem liga o caminhão nem define a rota permitida; ele apenas grava com exatidão a velocidade, as paradas, a duração da viagem e as frenagens ocorridas ao longo de todo o trajeto.

🔍 **Causa Raiz / Por que foi criado:** Durante um incidente de segurança ou fraude interna, os investigadores precisam comprovar matematicamente quem esteve conectado, quais comandos foram executados, que volume de dados foi transferido e em quais horários exatos.

🛡️ **Visão do Auditor de GRC:** Em conformidade com normas como PCI-DSS (Requisito 10) e ISO 27001, o auditor fiscaliza se os registros de accounting gravam data, hora, IP de origem, identidade do usuário e resultado da operação, sendo protegidos contra adulteração.

⚠️ **Como cai na Prova CompTIA:** Gatilhos da prova: 'Track user session duration', 'Log logon and logoff timestamps', 'Determine which department used network bandwidth for billing chargeback', 'Audit user activities'. Resposta: Accounting.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Usuário digita login e senha ou encosta o dedo no leitor biométrico	**Autenticação (Authentication - Provar quem é)**
Sistema concede acesso somente leitura à pasta da contabilidade com base no grupo	**Autorização (Authorization - O que pode fazer)**
Servidor registra que o usuário transferiu 2 GB de dados às 23h30 e desconectou	**Contabilidade / Auditoria (Accounting - O que foi feito)**
Protocolo AAA que opera em TCP porta 49 e criptografa todo o pacote de rede	**TACACS+ (Ideal para administração de roteadores e switches)**
Protocolo AAA que opera em UDP e combina Autenticação e Autorização	**RADIUS (Padrão para 802.1X, Wi-Fi corporativo e VPN)**
Porta física do switch só libera tráfego após validação de credenciais do dispositivo	**IEEE 802.1X (Port-Based Network Access Control)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa de serviços financeiros exige que qualquer funcionário que conecte um cabo Ethernet em uma tomada de parede precise se autenticar antes de obter acesso à LAN corporativa. O arquiteto de segurança propõe implementar controle de acesso à rede baseado em porta, de modo que os switches mantenham as portas em estado não autorizado até que o usuário seja validado por um servidor centralizado. Qual combinação de tecnologias atende melhor a esse requisito?

A) IEEE 802.1X com um servidor RADIUS

B) Filtragem por endereço MAC em cada porta do switch

C) Trunking VLAN 802.1Q com atribuições estáticas de porta

D) WPA2-Personal com chave pré-compartilhada

QUESTÃO 2 · CENÁRIO DE EXAME

Um funcionário insere credenciais válidas e faz login no aplicativo de RH da empresa. No entanto, ao tentar abrir um relatório de folha de pagamento, o sistema exibe 'Acesso Negado'. Qual componente do AAA é responsável por negar a solicitação de visualizar o relatório de folha?

A) Autenticação

B) Autorização

C) Contabilidade (Accounting)

D) Identificação

QUESTÃO 3 · CENÁRIO DE EXAME

A equipe de operações de rede de uma operadora de telecomunicações precisa controlar o acesso administrativo a centenas de roteadores e switches Cisco. O líder de segurança quer que cada administrador faça login com suas próprias credenciais, receba seu próprio nível de privilégio (por exemplo, nível 1 somente leitura, nível 15 admin total) e tenha todos os comandos registrados. O protocolo deve usar TCP para entrega confiável. Qual protocolo AAA é o mais adequado?

A) RADIUS

B) TACACS+

C) LDAP

D) Kerberos

QUESTÃO 4 · CENÁRIO DE EXAME

Durante uma auditoria SOC 2, a equipe de conformidade deve produzir evidências mostrando quem se conectou à VPN corporativa, os timestamps de cada sessão, a duração de cada sessão e o volume de dados transferido por usuário. Qual componente do AAA fornece esse rastro de auditoria?

A) Autenticação

B) Autorização

C) Contabilidade (Accounting)

D) Identificação

QUESTÃO 5 · CENÁRIO DE EXAME

Uma universidade quer que qualquer dispositivo conectado a uma tomada Ethernet do campus seja inspecionado antes de obter acesso aos sistemas internos. Dispositivos de docentes e funcionários que atendam aos requisitos de segurança (gerenciados pela universidade, patches atualizados, EDR instalado) devem ingressar na VLAN de docentes. Dispositivos de alunos que falhem nas verificações devem ser enviados a uma VLAN restrita de remediação onde possam baixar atualizações antes de serem reavaliados. Qual tecnologia a universidade deve implementar?

A) Prevenção de VLAN hopping com VLANs privadas

B) Network Access Control (NAC) com avaliação de postura (posture assessment)

C) Port security com endereços MAC sticky

D) Filtragem por endereço MAC nos switches de acesso

QUESTÃO 6 · CENÁRIO DE EXAME

Durante uma transação 802.1X, o laptop do usuário executa um cliente chamado supplicant.exe, o switch Ethernet recebe mensagens EAP e as encaminha para upstream, e um Windows Server executando Network Policy Service (NPS) toma a decisão final de permitir/negar. Qual papel o switch Ethernet desempenha nessa conversa?

A) Supplicant

B) Autenticador (Authenticator)

C) Servidor RADIUS

D) Autoridade certificadora

QUESTÃO 7 · CENÁRIO DE EXAME

Uma rede de varejo quer que funcionários autenticados sejam colocados na VLAN 10 (tráfego de ponto de venda), contractors autenticados na VLAN 20 (acesso limitado) e dispositivos não autenticados ou não conformes na VLAN 99 (somente guest/internet). Após autenticação RADIUS bem-sucedida, qual mecanismo informa ao switch em qual VLAN colocar a porta do usuário?

A) O segredo compartilhado (shared secret) do RADIUS

B) Atributos de autorização RADIUS como Tunnel-Type, Tunnel-Medium-Type e Tunnel-Private-Group-ID

C) A porta UDP 1813 de accounting do RADIUS

D) O endereço MAC do cliente que está se autenticando

QUESTÃO 8 · CENÁRIO DE EXAME

Um administrador de segurança configura um novo gateway VPN que exige que cada usuário remoto insira sua senha corporativa E um código de seis dígitos que rotaciona a cada 30 segundos em um token de hardware emitido pela empresa. Quais categorias de fatores de autenticação estão sendo usadas?

A) Dois fatores de conhecimento (algo que você sabe)

B) Dois fatores de posse (algo que você tem)

C) Algo que você sabe combinado com algo que você tem

D) Algo que você é combinado com algo que você sabe

QUESTÃO 9 · CENÁRIO DE EXAME

Um arquiteto de segurança está comparando protocolos para centralizar serviços AAA e percebe que um protocolo candidato criptografa apenas o campo de senha no pacote Access-Request, enquanto o outro candidato criptografa todo o payload de cada pacote, incluindo nomes de usuário e respostas de autorização. Qual protocolo criptografa todo o payload?

A) RADIUS, porque usa UDP para maior velocidade

B) TACACS+, que criptografa todo o corpo de cada pacote

C) Kerberos, que criptografa todo o tráfego usando AES

D) LDAP com StartTLS, que criptografa a sessão de diretório

QUESTÃO 10 · CENÁRIO DE EXAME

Quando um laptop BYOD se conecta à rede wireless corporativa, o agente NAC inspeciona a versão do sistema operacional, verifica se o mecanismo antivírus está em execução e não está desatualizado há mais de três dias, e confirma se o dispositivo faz parte do domínio corporativo. Se alguma verificação falhar, o dispositivo é colocado em uma VLAN de remediação com acesso somente aos servidores de patch e atualização de AV. Qual é o nome desse processo de inspeção?

A) Imposição de port security

B) Avaliação de postura (posture assessment / verificação de integridade do endpoint)

C) Fallback de autenticação MAC

D) VLAN hopping

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — IEEE 802.1X com um servidor RADIUS

O IEEE 802.1X é o padrão para controle de acesso à rede baseado em porta. O switch atua como autenticador, o supplicant é o software cliente no endpoint, e um servidor RADIUS toma a decisão de autenticação antes que a porta transicione para o estado autorizado. Filtragem por MAC, tagging VLAN e WPA2-PSK não fornecem essa autenticação dinâmica baseada em usuário no nível da porta.

Questão 2: Alternativa B — Autorização

A Autorização determina o que uma identidade já autenticada tem permissão de fazer. As credenciais verificaram a identidade do usuário (Autenticação), enquanto a lista de controle de acesso ou conjunto de permissões bloqueou o recurso específico, o que é uma decisão de Autorização. A Contabilidade registra o que o usuário fez depois; a Identificação é apenas apresentar uma reivindicação de identidade (por exemplo, um nome de usuário).

Questão 3: Alternativa B — TACACS+

O TACACS+ foi projetado para administração de dispositivos. Ele separa Autenticação, Autorização e Contabilidade em funções independentes (arquitetura AAA), suporta níveis de privilégio por usuário ou grupo, criptografa todo o payload (não apenas a senha) e usa a porta TCP 49 para transporte confiável. LDAP e Kerberos são protocolos de diretório/autenticação, não frameworks AAA para administração de dispositivos de rede.

Questão 4: Alternativa C — Contabilidade (Accounting)

A Contabilidade captura e registra o que os usuários autenticados e autorizados realmente fizeram: horários de início/fim de sessão, duração, bytes transferidos, comandos executados e recursos acessados. Esse rastro é o que os auditores analisam. A Autenticação verifica a identidade, a Autorização concede permissões e a Identificação é a apresentação inicial de um nome de usuário (não uma identidade verificada).

Questão 5: Alternativa B — Network Access Control (NAC) com avaliação de postura (posture assessment)

O Network Access Control (NAC) avalia a postura de segurança dos endpoints que se conectam (versão do SO, status do AV/EDR, patches, certificados) e os atribui a VLANs com base no resultado da avaliação de postura. VLANs de remediação são um padrão clássico de NAC. O port security apenas limita quais endereços MAC podem usar uma porta; ele não inspeciona a saúde do endpoint. Filtragem por MAC e VLANs privadas não realizam verificações de integridade.

Questão 6: Alternativa B — Autenticador (Authenticator)

No 802.1X, os três papéis são: Supplicant (o software cliente no endpoint), Autenticador (o switch ou AP que controla a porta) e Servidor de Autenticação (o servidor RADIUS/NPS que toma a decisão de política). O switch neste cenário é o Autenticador — ele impõe o estado autorizado/não autorizado da porta com base no que o servidor RADIUS decide.

Questão 7: Alternativa B — Atributos de autorização RADIUS como Tunnel-Type, Tunnel-Medium-Type e Tunnel-Private-Group-ID

Os atributos de autorização RADIUS — particularmente Tunnel-Type, Tunnel-Medium-Type e Tunnel-Private-Group-ID (RFC 2868) — instruem o switch a colocar o endpoint que está se autenticando em uma VLAN específica. É assim que a atribuição dinâmica de VLAN funciona. O segredo compartilhado autentica a própria conversa RADIUS, a porta 1813 é para accounting, e o endereço MAC é usado apenas para identificação, não para atribuição de VLAN.

Questão 8: Alternativa C — Algo que você sabe combinado com algo que você tem

A senha é 'algo que você sabe' (fator de conhecimento) e o token de hardware rotativo é 'algo que você tem' (fator de posse). Combiná-los cria autenticação multifator. Fatores biométricos ('algo que você é') não estão presentes. Dois fatores da mesma categoria não constituiriam autenticação multifator verdadeira.

Questão 9: Alternativa B — TACACS+, que criptografa todo o corpo de cada pacote

O TACACS+ criptografa todo o corpo (payload) de cada pacote entre o cliente AAA e o servidor, incluindo nome de usuário, atributos de autorização e registros de accounting. O RADIUS criptografa apenas o campo de senha no pacote Access-Request, deixando nomes de usuário e outros atributos legíveis para qualquer pessoa que capture o tráfego. Este é um dos principais motivos pelos quais o TACACS+ é preferido para acesso administrativo a dispositivos de rede.

Questão 10: Alternativa B — Avaliação de postura (posture assessment / verificação de integridade do endpoint)

A avaliação de postura (também chamada de health check ou conformidade do endpoint) é o processo do NAC que inspeciona o estado de segurança de um endpoint — versão do SO, status do AV, associação ao domínio, certificados — e decide se concede acesso total, nega acesso ou redireciona para uma rede de remediação. Port security é um recurso

de Camada 2 que limita endereços MAC; autenticação MAC é um método separado de fallback do 802.1X; VLAN hopping é um ataque, n��o uma função de NAC.